

한전KDN(주) 상임감사

통보 및 시정요구

제 목 [] 연간 추진계획·컨설팅 결과 이행 및 업무 연속성 수립 미흡
소 관 부 서 []
조 치 부 서 []
구 분 보안관리
내 용

1. 업무 개요

[]은 사내 [] 및 []보호와 관련된 정책을 수립하고 관리하며 [], [], [] 등 대외기관에서 실시하는 보안 감사를 대응하는 업무를 담당하고 있다. 또한 []과 관련해 수립한 정책을 회사 임직원들이 준수하고 있는가에 대한 점검과 []에 필요한 시스템을 도입·운영하는 업무를 수행하고 있다.

그리고 []은 회사 정보시스템 및 정보보호 관리체계에 대한 종합적인 대응 체계를 구축하고, 상급기관에서 실시하는 [] 평가에 대비한 국한된 취약 사항 분석 및 조치와 사내에서 운영 중인 정보시스템 전체에 대해 취약사항을 종합적으로 분석하고 도출된 취약사항에 대한 조치를 취하기 위해 0000년에 컨설팅 용역¹⁾을 실시하였다.

1) 「[] 종합 컨설팅 용역」, 기간: 0000. 00.00. ~ 0000.00.00.(00일), 발주금액: xxx,xxx,xxx원(VAT포함)

2. 관계 법령·규정 및 판단기준

「■■■■ 절차서」 4.1(연도 추진계획 수립) 1)에 따르면 ■■■■ 담당부서 직원은 매년 ♡♡♡안전대책을 포함한 「연도 ■■■■업무 추진계획」을 수립·시행 하여야 한다고 규정하고 있다.

그리고 같은 절차서 6.6.1(업무연속성 관리체계 수립)에 따르면 사내 정보관리 시스템, ICT인프라 설비 및 통신설비/네트워크를 운영·관리하는 부서장은 정보시스템 중단으로 인한 업무마비를 최소화하기 위해 ① 정보자산 및 프로세스에 대한 위험 분석, 우선순위를 결정하고, ② 업무 중단에 대한 영향분석과 업무연속성 목표수준 정의를 설정하며, ③ 각각의 책임과 업무연속성 계획에 대해 인식하고 협의하여야 한다. 또한, ④ 업무연속 전략과 계획 수립을 문서화하고, ⑤ 업무연속성 계획 실행에 대한 교육을 실시하며, ⑥ 계획과 관리체계에 대한 정기적인 테스트와 업데이트를 실시하는 것을 고려하여 업무연속성 관리체계를 수립하여야 한다고 규정하고 있다.

3. 감사결과 확인된 문제점

가. ■■■■ 연간 추진계획 이행 미흡

■■■■이 ○○○○년에 계획한 “◆◆◆◆ 보호업무 추진계획 수립”에서 계획한 과제의 이행여부를 점검한 결과 [표 1]과 같이 수립한 xx개의 세부 추진 과제 중 x개의 과제 진행이 미흡하였다.

세부실천과제 이행이 미흡한 x개의 세부과제와 관련해 ■■■■에서는 ① “◆◆◆◆ 영향평가 및 외부용역 진단”과 관련해서 산업통상자원부 소속 ◆◆◆◆보호 위원회에서 실시하는 ○○○○년 ◆◆◆◆ 보호수준 평가에 대비해 외부기관에 컨설팅을 의뢰하겠다고 하였으나 ◆◆◆◆를 보유하고 있는 부서의 협조가 어렵다는 이

유로 실시하지 않았으며, ② “◆◆◆◆처리시스템 ●●●●진단용역”은 ▷▷▷▷
▷가 관리하는 ◆◆◆◆처리시스템과 □□□□□에서 관리하는 ◆◆◆◆보호 솔루션
중 대상을 선정해 ●●●● 점검을 실시하겠다고 계획했으나, □□□□□에서 관
리하는 솔루션은 제외하고, ▷▷▷▷▷에서 관리하는 시스템 중 일부를 선정해 ●
●●●● 진단을 실시하고 조치이행을 ▷▷▷▷▷에 요구한 것으로 확인되었다.

[표 1] ○○○○년 ◆◆◆◆ 보호업무 추진 과제 내역

[illegible]

자료: ◆◆◆◆보호 업무 세부추진계획 실적 확인 재구성

따라서 연간 추진계획에 따른 이행실적을 높이기 위해서는 계획 단계부터 관련 부서와의 소통을 통해 대외기관 평가관련 이해를 높이고 협조를 얻어 계획을 수립하여야 하며, 취약점 진단은 사내의 정보보호와 관련한 업무를 총괄하는 부서로서 □□□□□ 자체에 대한 점검도 실시하여야 한다.

나. □□□□ 종합 컨설팅 결과 이행 미흡

□□□□□에서 ○○○○년도에 시행한 「**□□□□** 종합 컨설팅 용역」 결과로 제
시된 개선사항의 이행여부를 확인하였으며, [표 2]와 같이 xx개의 관리적 취약점 중
정보자산 관리와 관련된 x개 항목에서 이행 조치가 미흡한 것으로 확인되었다.

[표 2] ○○○○년 □□□□ 컨설팅 결과에 대한 이행 여부

[illegible]

자료: 컨설팅 용역 결과 자료 재구성

컨설팅용역 결과 제시된 사항의 이행 미흡 사례로는 핵심 자산(●●, ●● ●●, ●●, ●●, ●●, ●● 등)의 현황 파악과 더불어 자산의 연결(●● ●●, ●●, ●●, ●● ●● 이어지는 자산의 연결)을 요구하였으며, 개선을 위해 □□□□□에서 구축한 ■■■■포털의 기능은 ●●와 연계한 단순 자산관리 기능으로 컨설팅에서 요구하는 자산의 연결기능 요구를 충족했다고 볼 수 없다.

따라서 □□□□□에서 관리하는 ■■■■포털의 기능을 보완하여 컨설팅 결과에서 요구한 사항을 충족할 수 있도록 조치를 취해야 한다.

다. ■■■■ 시스템에 대한 업무 연속성 관리체계 수립 미흡

□□□□□에서 운영·관리하는 ■■■■ 솔루션 및 보안 설비에 대하여 업무 연속성 관리체계 수립 여부를 확인한 결과, ■■■■ 시스템의 업무 연속성 관리체계 수립 내용과 운영·관리한 실적은 확인할 수 없었다.

또한 □□□□□은 ■■■■ 관련 시스템을 운영·관리하는 총괄 조직임에도 불구하고, 해당 시스템의 업무 연속성 관리체계 수립 책임이 ▷▷▷▷▷에 있다고 생각하는 등 역할과 책임에 대한 인식이 부족한 것으로 확인되었다.

따라서 업무 연속성 관리체계 수립과 관련된 대부분의 업무가 사내 시스템을 총괄하는 ▷▷▷▷▷의 업무이지만, ■■■■ 관련 시스템을 실질적으로 운영·관리하는 주체인 □□□□□은 ■■■■ 시스템의 중단으로 인한 업무마비를 최소화하기 위해 업무 연속성 측면에서의 분석과 관리체계 수립 업무를 수행하여야 한다.

관계부서 의견

□□□□□은 연간 계획 수립과 관련하여 계획한 사항을 모두 이행하도록

노력하며, □□□□□에서 관리하는 ■■■■포털을 보완하여 컨설팅에서 요구한 사항을 이행할 수 있도록 개선하겠다는 의견을 제시하였다. 또한 운영 중인 시스템에 대한 업무 연속성 수립이 미흡했음을 인정하였으며, 업무 연속성 관리체계를 수립하겠다는 의견을 제시하였다.

조치할 사항

□□□□□장은

① 연간 ■■■■ 및 ◆◆◆◆보호 관련 추진 계획에 대하여 해당 연도에 모두 이행할 수 있도록 관리하기 바라며, ■■■■ 종합 컨설팅 결과에서 제시한 개선사항에 대하여 이행방안을 마련하기 바랍니다. (통보)

② □□□□□은 ■■■■ 시스템에 대한 업무 연속성 관리체계를 수립하고 ▷▷▷▷▷와 공유하기 바랍니다. (시정)